SECURITY REPORT

Tideway

An AI that can read, analyse and propose,
but can never approve or move money.

FINTECHATHON 2026 | TOPIC E
The Last BrainCell, BUET, Bangladesh
github.com/SadManQT/tideway

Synthetic sandbox only. No real money, bank, lender, supplier or customer is connected.

01 Security model

Authority lives in code, never in the model

Tideway assumes the AI can be hijacked and the human can be careless. Money can only move through a PIN-approved, signed, scoped and expiring mandate.

30/30	25/25	551	0
self-test cases passed	simulated attacks blocked	automated tests passing	money-moving AI tools

Permission tiers

Tier	Who	What it allows
Read	Agent, all members	Forecasts, risk, records, evidence. Changes nothing.
Propose	Agent, owner, accountant	Builds recovery bundles with risk before and after. Cannot approve.
Approve	Owner, accountant (people only)	PIN step-up. Large plans need two people, one the owner, plus a typed exposure amount.
Execute	Signed mandate only	One idempotent sandbox execution, state hashes before and after, read-back check.
Administer	Owner	Policy, team, kill-switch resume (with a reason), payee verification.

THE GOLDEN RULE

No text, message or model output can approve or execute a payment. Moving money is never delegated.

Tenant and session protection

- Membership and role checked on every request; businesses never see each other.
- Loopback-only server, strict Content-Security-Policy, CSRF token, strict JSON field allow-lists.
- Rate limits on requests and logins; PINs stored as salted hashes.

02 Controls

From proposal to receipt, with proof

1 Propose
Agent builds bundles and shows the remaining risk. It has no approve tool.

2 Approve
PIN step-up. Large plans need two people, one the owner.

3 Mandate
HMAC-signed, bound to exact actions, snapshot and policy; expires.

4 Execute
Once only. Before and after hashes, read-back verification.

Runtime safeguards

1	**Kill switch** Pauses planning and execution instantly. Only the owner can resume, with a reason.
2	**Circuit breaker** Repeated security denials pause the agent automatically.
3	**Payee fraud check** Changed bank details or look-alike names block every action on the bill until verified by callback.
4	**Separation of duties** Whoever verified a payee cannot be the only approver of payments to it.
5	**Injection screening** Hidden characters stripped, eight languages screened, suspicious text quarantined as data.
6	**Autonomy dial** Advise, Propose or Delegate. Delegate only sends zero-cash reminders, capped per day.

Privacy for the optional cloud model

- Off by default; the on-device path is the default.
- Per-message consent, pseudonymised names, no free text from records.
- Every number in an answer is checked against tool output; a privacy inspector shows the exact payload first.

03 Proof and audit

Every action leaves tamper-evident evidence

AUDIT CHAIN

Hash-chained log + witness

Each entry is chained to the previous one and checkpointed by a separately keyed witness. Edits, deletions and truncation are detected.

LIVE DRILL

One-click tamper drill

Edits a safe copy and shows verification breaking at the exact entry that changed.

CREDIT PASSPORT

Signed, expiring lender summary

HMAC under a separate sub-key, 30-day expiry. Issuing needs a PIN and is audited; any edit fails verification.

ISOLATION

Lender radar never sees tenants

The portfolio radar runs on its own synthetic portfolio and does not import the store; a test enforces it.

Threats and mitigations

Threat	Mitigation
Hijacked AI model	Plan validator: known read/propose tools only, typed arguments, names resolved against the ledger. Forbidden tools trip the circuit breaker.
Prompt injection in messages	Text is quarantined as data and never gains authority. Inbox output is a draft until a person confirms.
Payment redirection fraud	Changed account or look-alike payee blocks the bill; callback verification and separation of duties.
Replay or tampered mandate	Signed, single-use, expiring mandates bound to snapshot and actions; idempotent execution.
Cross-tenant access	Membership and role re-checked on every request and every consequential action.
Log tampering	Hash chain plus independent witness checkpoint; truncation detected.

04 Verification and scope

What was measured, and what is not claimed

Check	Result
Self-test scorecard	30 of 30 cases: 5 tasks completed, 25 attacks blocked, assuming a hijacked model.
Automated test suite	551 tests passed, 4 skipped (Windows, Python 3.11.9).
Judge flow, end to end	Login, three businesses, propose, two-person approval, execute with read-back, audit drill and all exports passed; no server errors.
Treasury evidence	13-week cash flow reconciles exactly with the projection for all three businesses; passport tamper, expiry and wrong-business checks pass.
Help layer	Tested to make no network calls and hold no approval or execution authority.

Scope

- Synthetic sandbox: fictional businesses and simulated counterparties; no real money moves.
- Demo-grade PINs and keys. HMAC signatures are verifiable by the issuing instance; production would add asymmetric signatures.
- Message screening can miss unfamiliar attacks, so safety rests on permissions, not on detection.
- Next: independent penetration test and consented pilots with real SMEs.

> **DESIGN PRINCIPLE**
>
> Detection helps, but permissions decide. Even a fully compromised model cannot approve, sign or execute.